שלבי טיפול בבקשות של אנשים (עיון, תיקון, מחיקה) (אנגלית, המקור)

מסמך	שלבי טיפול בבקשות של אנשים (עיון, תיקון, מחיקה) (אנגלית, המקור)
נתיב המקור	docs/privacy/en/03-data-subject-request-handling.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

נוסח אנגלי: המקור, והעברי (03) עוקב אחריו סעיף אחר סעיף. הנוסח העברי נמצא באותה תיקייה.

---

03 - Handling requests from people about their data (access, correction, deletion)

Status: DRAFT operating steps for the organisation's building manager. Not legal advice. Verified against `origin/integ/290` @ `018795f96` (2026-10-19). `B/` = `smplwise_vms/backend/smplwise/`. The notices shown to technicians say that requests go to "the building manager" (`NOTICE_TEXT` in `B/services/access_grants.py`); this document is what that person does. Everything about the legal side - who may ask, what must be answered, deadlines, identity checks, fees, exemptions, what may be refused - is **REQUIRES COUNSEL REVIEW (C11)**; the steps below only describe what the product can and cannot do today.

1. Receive and record

1. Write down: date received, how (phone, mail, in person), the person's name as they gave it, what they ask (see / correct / delete / other). Keep this log outside Arx (Arx has no request-log feature). Keep the minimum personal data in the log. **REQUIRES COUNSEL REVIEW (C11)**: how long the log is kept.
2. Confirm who is asking before disclosing or deleting anything. The product has no identity-proofing step. A technician's number in the directory was typed by a vendor, so a request from "the technician" can be matched by name and phone, but how strongly to verify is **REQUIRES COUNSEL REVIEW (C11)**.
3. Note the deadline the organisation has decided to work to. **REQUIRES COUNSEL REVIEW (C11)** (the period and its start).

2. Find the person's data (checklist)

Where	How	Who can do it (`02-retention-and-access-summary.md`, section 3)
Directory row (name, company, phone, e-mail, notes, language, assignments)	directory screen / `GET /tickets/contacts`, `GET /tickets/contacts/{id}` (`B/routers/tickets_contacts.py`)	`tickets.configure`
Pending / accepted vendor-added technician	access screen "external" tab; `access_pending_contacts`	`access.external.grant` or `tickets.configure`
Door-access grants of the person (doors, dates, state, who approved)	`GET /access-grants?all=true` (no per-person filter exists; find the person in the list, `B/routers/access_grants.py`)	`access.external.grant`

Where	How	Who can do it (`02-retention-and-access-summary.md`, section 3)
Door-system person (name, category, responsible person, purpose, entries, entry pictures if enabled)	the door system itself (WisKey); Arx keeps only the link `access_person_links`	door-system operator. Retention there **REQUIRES COUNSEL REVIEW (C7)**
Tickets and timeline lines the person wrote (note text, photos, link-access log)	the tickets screen; the export below returns the timeline lines	department managers
Free text that mentions the person (ticket description, notes, place text)	search in the tickets screen. The export does not cover text written by others	department managers
WhatsApp messages sent to the person	`intercom_messages` keeps the sender, time, template and length, not the text; ticket messages: `ticket_outbox` (90 days)	administrators
Audit rows about the person	audit screen; rows carry ids (e.g. `contact:<id>` or a contact id), not names	`audit.read`
Phone-app presence (staff only)	the user's devices and event log	`presence.sensors.view`
Backups	zip files in the add-on data directory (and any copies elsewhere)	system administrator. Handling of backups **REQUIRES COUNSEL REVIEW (C8)**

3. Access ("what do you hold about me")

1. Use the directory export: `GET /tickets/contacts/{id}/export` (`B/services/tickets/contacts.py` `export`; audited as `ticket.contact.export`). It returns: the directory row (id, kind, name, company, phone, e-mail, channel, flags, language, notes, active, dates, erased time), department ids, assignments (ticket number, dates, end reasons), the timeline lines the person wrote (ticket number, time, kind, status change, text) and cost claims.
2. The export does **not** include: door-access grants, the door-system record and entry log, the notice-acknowledgement rows, free text written by others about the person, message logs, audit rows. (The 2.7.1 legal brief records the access-grant gap as "not built"; it is still not in `export`.) Add these by hand from section 2. Whether a manual compilation is acceptable: **REQUIRES COUNSEL REVIEW (C11)**.
3. Do not hand over other people's data (for example the vendor's other technicians, other staff names in notes).
4. Record what was sent and when.

4. Correction

1. Edit the directory row (`PATCH /tickets/contacts/{id}`). Changing the phone or e-mail, or setting the row inactive, while the person holds a live handler link revokes the link at once and puts the ticket in "waiting for the manager" (`B/services/tickets/contacts.py` docstring). A changed number also clears the phone confirmation, so a technician's personal entry code will not be sent until the number is confirmed again (`phone_confirmed_at` check in `access_grants.number_problem`).
2. A name or detail held in the door system is corrected in the door system. Arx has a rename call in its door-system client (`B/services/access_grant_engine.py`); whether any screen uses it for a correction was not checked.

3. Names inside free-text ticket notes are not edited by any product feature; a manager decides case by case. **REQUIRES COUNSEL REVIEW (C11)**.

5. Deletion

Decide first whether any legal duty to keep the data exists (financial records, audit, security incidents): **REQUIRES COUNSEL REVIEW (C10, C11)**. Then, in this order:

1. **Live door access.** If the person has a live grant, revoke it first (access screen, `POST /access-grants/{id}/revoke`). The directory erase and the "needs review" delete are refused while a live grant exists. Revocation is confirmed by the door system; the grant can stay in state `revoking` until it is.
2. **Pending technician nobody approved.** Use "reject and delete" (`POST /access-grants/pending-contacts/{id}/reject`): ends open requests, then runs the directory erase. It is refused if a door-system link or a decided grant exists.
3. **Any other directory person.** `POST /tickets/contacts/{id}/erase` with the "also from history" option (replaces the frozen name on assignments and timeline rows with the tombstone). People idle for 12 months and technicians pending for 30 days are listed in the "needs review" segment (`GET /tickets/contacts-review`, handlers page `seg=review`); its "delete now" does the same erase after re-checking the rule. A vendor that still has persons cannot be erased until they are.
4. **The person in the door system.** Arx never deletes it as part of the steps above. For a person Arx created, an administrator uses "delete person" (type the confirmation word; `POST /access-grants/links/{link_id}/delete-person`) after all grants are revoked. For a person created in the door system, delete in the door system. What the door system then does with its entry records is not verified: **REQUIRES COUNSEL REVIEW (C7)**.
5. **Tickets.** If the person's data sits mostly in ticket content, a manager with `tickets.delete` can delete the whole ticket (reason is audited; the audit row holds no content, `B/services/tickets/deletion.py`). Cost claims in `approved`/`paid` status block deletion unless the manager also holds `tickets.costs`.
6. **What remains after steps 1-5 (facts):** the directory row as a tombstone; access-grant rows (ids, doors, dates, end reason `contact_erased`) until 12 months after they ended; audit rows (365 days by default); cost-claim records (company, amounts, files, 7 years by default); free text written by others; backups already written (5 pre-upgrade + 7 daily, plus any manual copies); WhatsApp-provider and door-system copies. Whether and how to tell the person: **REQUIRES COUNSEL REVIEW (C11)**.

6. Reply and close

Reply in the language the person used (the notices exist in he/en/ar/ru). Record the date of the reply and what was done. If the request is refused or only partly met, the reason and what is told to the person: **REQUIRES COUNSEL REVIEW (C11)**.

7. Gaps in the product that affect these steps (for the organisation's information)

- The export lacks door-access data (section 3).
- No automatic deletion of directory persons, of door-system persons, or of closed tickets (`02-retention-and-access-summary.md`, section 1).
- Erase does not touch free text written by others and does not touch backups.
- No request log, no deadline tracking, no identity-proofing step.